
IT-STD-50-11 IT Secure Development Standard

PRINTED OR OFFLINE VERSIONS OF THIS DOCUMENT ARE FOR HISTORICAL USE ONLY UNLESS SUCH VERSIONS ARE CONTROLLED.

1.0 PURPOSE AND SCOPE

The security of General Dynamics Information Technology's (GDIT's) information systems is a critical component of the business. The Information Technology (IT) security architecture, designed to protect these information systems, must combat threats from both external and internal sources. This Standard was developed to ensure consistent secure coding design, development, configuration, implementation, and/or operations by augmenting, and working in conjunction with, the requirements set forth in IT-HB-50-1C GDIT Cyber Security Handbook and IT-MAN-50-A GDIT IT Cyber Security Procedure Manual.

This Standard applies to all custom web applications, shell scripts, software development libraries, and programs written by, or on behalf of, GDIT and utilized on the GDIT Network. This Standard also applies to vendor Software as a Service (SaaS) or Commercial-Off-the-Shelf (COTS) applications contracted by GDIT for use by its employees, suppliers, or partners, as related to any development, coding or scripting to modify or extend an application to support GDIT requirements related, but not limited to, user interface modifications, system interfaces, reports, or workflows.

Each GDIT service and/or application is required to meet the standards described below. Services may exceed these standards, as appropriate, to meet their unique business requirements. New development efforts that commence after publication of this Document shall comply with the standards described within it. Pre-existing software shall be modified to comply with this Document at the next reasonable opportunity as changes to the application service or processes are being implemented.

Deviations from this Standard shall only be permitted when there are technical limitations or a significant impact to the business. If a requirement/standard cannot be implemented, the IT Professional responsible for the system, application, service, or asset shall refer to IT-HB-50-1C GDIT Cyber Security Handbook and IT-MAN-50-A GDIT IT Cyber Security Procedure Manual, regarding the variance process.

2.0 ORGANIZATIONAL UNITS AFFECTED

This Standard affects all IT Professionals within Global Chief Information Officer (GCIO) Services, unless otherwise expressly noted.

3.0 ROLES AND RESPONSIBILITIES

Role	Responsibility
IT Professional	A technically experienced professional who works in a computing environment and manages and handles system or server components related to core IT management, support, consultation, resourcing, and development

4.0 STANDARD

4.1 Security Guidelines

4.1.1 Security Requirements

All IT Professionals implementing or managing GDIT IT resources shall ensure that solutions are provisioned and maintained according to the Security Controls defined in

IT-STD-50-11 IT Secure Development Standard

IT-MAN-50-A GDIT IT Cyber Security Procedure Manual and aligned with the requirements defined in IT-HB-50-1C GDIT Cyber Security Handbook.

As part of the GCIO Services System Development Lifecycle (SDLC), for any new software acquisition and implementation, GDIT IT Professionals shall adhere to all project lifecycle gates and processes, as defined in IT-LFC-1 GCIO Services – Applications and Architecture Lifecycle. This includes, but is not limited to, Intake, Business Case, 3rd Party Risk Assessment (3PRA), Initiative Review Board (IRB), IT Request Steering Committee (IRSC), Architecture Review Board (ARB), Detailed Design Review (DDR), and Operational Readiness Review (ORR). GDIT Cyber Security Team is involved and is an approving member throughout this Lifecycle.

4.1.2 Secure Development Environments

All development, test, and user acceptance testing environments shall be logically separated and segregated (from network, infrastructure, and database standpoints). All environments shall have separate logins, which are governed by GCIO Services' access controls and data security processes. System development and integration efforts throughout the SDLC follow the guidelines provided in IT-HB-50-1C GDIT Cyber Security Handbook and IT-MAN-50-A GDIT IT Cyber Security Procedure Manual.

4.1.3 Data Security & Access Controls

Information security shall be integrated into all phases of the IT-LFC-1 GCIO Services – Applications and Architecture Lifecycle to ensure appropriate protection for the information that the system will transmit, process, and store, in compliance with GDIT Enterprise Data Protection Policies. The principle of Least Privilege must be followed, allowing only authorized access for users (or processes acting on behalf of users) who are necessary to accomplish assigned tasks, in accordance with their assigned mission and/or business functions. Separation of Duties shall be logically implemented to ensure that no single person is able to introduce fraudulent or malicious code or data without detection. Role-based access controls shall be implemented to ensure Separation of Duties is enforced and Least Privilege access is maintained. Data access is approved by System and Data Owners. Access may be granted based on functional roles, project, division, or program. More detailed guidelines are provided in IT-HB-50-1C GDIT Cyber Security Handbook and IT-MAN-50-A GDIT IT Cyber Security Procedure Manual.

4.1.4 Secure Development

All coding conventions and guidelines shall comply with GDIT Cyber Security policies for system access, authentication, audit logging, data encryption and data validation against security threats, in accordance with IT-MAN-50-A GDIT IT Cyber Security Procedure Manual and aligned with the requirements defined in IT-HB-50-1C GDIT Cyber Security Handbook. Code shall be tested throughout the SDLC to ensure security requirements are met. Any custom code developed shall be peer-reviewed and approved prior to production deployment. When applicable, penetration testing may be performed to detect software vulnerabilities. Coding conventions and guidelines may vary based on the application and programming language. Open-Source Code is permitted; however, it shall comply with the standards outlined within this Document.

IT-STD-50-11 IT Secure Development Standard

4.1.5 Source Code Management

All source code shall be stored within a secure source code repository. Access to the code repository shall be controlled on a user account basis. Access must be restricted and shall be requested, reviewed, and granted based on role and responsibilities. Access to source code shall be controlled across projects and granted based on the role and service of the requester. Code changes shall be tracked using version control. When applicable, source code restoration from backup shall be tested annually to confirm that code can be rebuilt from source.

4.1.6 Code Deployment

Access between development and production environments shall be restricted and limited to authorized personnel. All changes shall be deployed to production environments, in accordance with IT-PRC-8-0-A GCIO Services Change Management Process. Privileged access to production environments to deploy code changes must be limited to the developers and/or application administrators. Separation of Duties must be maintained throughout the deployment lifecycle, in accordance with IT-MAN-50-A GDIT IT Cyber Security Procedure Manual and IT-PRC-8-0-A GCIO Services Change Management Process.

4.1.7 Error Handling

Proper error and exception handling shall be implemented for the operation and maintenance of an application. A consistent error handling approach shall be utilized for a given application. Error handling shall be performed in a manner that reduces the risk of information leakage. An application shall fail in a safe and secure manner. No information shall be displayed that could be useful in exploiting the application, including, but not limited to, server or database identification or account credentials.

4.1.8 Test Data

Test data shall be selected and controlled based on the type and data classification in scope for the system. Test data may include random test data or, in some cases, masked or scrambled data, when required. Test data shall be protected and controlled through the controls specific to, and documented for, the secure development environment.

4.1.9 Data Masking

Data masking shall be used during exception scenarios when software development is outsourced to third parties; specifically, when offshore resources are utilized. Otherwise, data masking is not required, since per our documented controls, development and test systems mirror production access controls, so there is low risk of data exposure. IT personnel will be authorized to access data based on role and access needs. In addition, data encryption on enterprise systems and the separation and segregation of development and test systems, per IT-HB-50-1C GDIT Cyber Security Handbook and IT-MAN-50-A GDIT IT Cyber Security Procedure Manual, further mitigate the risk.

4.1.10 Outsourced Development

Outsourced system development shall be obtained through a contractual agreement between GDIT GCIO Services and a third-party service provider (vendor), or between GDIT GCIO Services and an internally sourced service provider through an Inter-company Support Agreement (ISA) and Operational Level Agreement (OLA).

IT-STD-50-11 IT Secure Development Standard

Outsourced development resources are screened following the GDIT contractor screening process, in accordance with IT-HB-50-1C GDIT Cyber Security Handbook. The vendor will be provided non-employee network access and access to the development systems to develop, and unit test the vendor's custom code. The vendor shall comply with all GDIT secure design, development, code management, and testing standards. All code must be peer reviewed by a GDIT IT Professional before the GDIT IT Professional checks the code into the source code repository. All custom code will be deployed to production in accordance with IT-PRC-8-0-A GCIO Services Change Management Process. GDIT retains ownership of all code developed by an outsourced third party.

5.0 ACRONYMS AND MEANINGS

Acronym	Meaning
3PRA	3 rd Party Risk Assessment
ARB	Architecture Review Board
CCF	Cyber Security Framework
COTS	Commercial Off-the-Shelf
CP	Corporate Policy
CSHB	Cyber Security Handbook
DDR	Detailed Design Review
GCIO	Global Chief Information Officer
GD	General Dynamics
GDIT	General Dynamics Information Technology
IRB	Initiative Review Board
IRSC	IT Request Steering Committee
ISA	Inter-company Support Agreement
IT	Information Technology
NIST	National Institute of Standards and Technology
OLA	Operational Level Agreement
ORR	Operational Readiness Review
SaaS	Software as a Service
SDLC	System Development Lifecycle
SSDF	Secure Software Development Framework

6.0 REFERENCES

General Dynamics Cyber Security Handbook (GD CSHB), Version: 02/13/2025, Effective Date: 1/1/2025.
GD CSHB, Appendix H – Secure Coding Standards, Version 01/01/2025.
IT-POL-50 Cyber Security Policy
IT-PRC-8-0-A GCIO Services Change Management Process
IT-PRC-50-0-B Third Party Risk Assessment Process
IT-HB-50-1A GDIT Employee/Non-Employee Cyber Security Handbook
IT-HB-50-1C GDIT Cyber Security Handbook
IT-MAN-50-A GDIT IT Cyber Security Procedure Manual

IT-STD-50-11 IT Secure Development Standard

IT-LFC-1 GCIO Services – Initiatives and Architecture Lifecycle

IT-FORM-50.05.01 Security Control Variance Request Form

National Institute of Standards and Technology (NIST) Special Publication 800-218, Secure Software Development Framework (SSDF), Version 1.1, Recommendations for Mitigating the Risk of Software Vulnerabilities, National Institute of Standards and Technology, Gaithersburg, MD, February 2022.

(<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-218.pdf>)

7.0 DOCUMENT APPROVAL / CHANGE HISTORY RECORD

Issue Date	Approvals		Change Description
03/11/2026	Tod Pierce, Document Owner	Kavita Sanghvi, Document Approver	<u>2026 Annual Review</u> - Replaced references to IT-STD-50.03 Cyber Control Framework Standard and Template and IT-HB-50-1B GDIT IT Professional Cyber Security Handbook, with references to IT-HB-50-1C GDIT Cyber Security Handbook and IT-MAN-50-A GDIT IT Cyber Security Handbook, as appropriate throughout this Standard - In Section 1.0 Purpose and Scope, added 2nd paragraph: "This Standard applies to..." - In Section 2.0 Organizational Units Affected, removed reference to GDIT Development Teams - Merged the former Section 4.1.2 Security Reviews into Section 4.1.1 Security Requirements and updated first paragraph
03/18/2025	Tod Pierce, Document Owner	Kavita Sanghvi, Document Approver	<u>2025 Annual Review</u> Added new Section 4.1.10 Data Masking
03/11/2024	Tod Pierce, Document Owner	Kavita Sanghvi, Document Approver	Initial Release